

Matriz de Evaluación PRAGMATIC para métricas SSVC a nivel nacional

Para cada métrica definida en el marco GQM, se evalúa cualitativamente su grado de cumplimiento de los nueve criterios PRAGMATIC: Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente, Rentable. [web:27][web:32][web:33][web:19][web:6]

Escala sugerida (cualitativa, reconvertible a numérica si se desea):

- Alto
- Medio
- Bajo

1. Leyenda breve de criterios PRAGMATIC

- Predictivo: capacidad de anticipar resultados futuros (riesgo, incidentes).
- Relevante: alineación con objetivos nacionales y regulatorios.
- Accionable: capacidad de guiar decisiones concretas.
- Genuino: resistencia a la manipulación; refleja la realidad.
- Significativo: fácil de interpretar; comunica algo importante.
- Preciso: estabilidad y exactitud de la medida.
- Oportuno: puede obtenerse con la frecuencia adecuada.
- Independiente: no duplica información de otras métricas; aporta algo nuevo.
- Rentable: coste razonable de obtención y mantenimiento.

2. Matriz PRAGMATIC por métrica

2.1. Capa de datos

M1.1 – % de CVE relevantes con evaluación SSVC básica

Criterio	Evaluación	Comentario
Predictivo	Medio	Contribuye indirectamente a capacidad de priorización, pero no predice incidentes por sí mismo.
Relevante	Alto	Directamente alineado con objetivo de disponer de datos SSVC para priorización nacional. [web:19][web:22][web:25]
Accionable	Alto	Permite fijar objetivos (“queremos $\geq X\%$ ”) y orientar esfuerzos de Vulnrichment y acuerdos de datos.
Genuino	Medio	Puede inflarse marcando “completo” con datos superficiales; requiere controles de calidad.
Significativo	Alto	Fácil de explicar: “qué parte del universo de vulnerabilidades conocemos bien”.
Preciso	Medio	Depende de la definición de “CVE relevante”; requiere criterio consistente.
Oportuno	Medio	Actualizable mensualmente; la latencia es aceptable para planificación, no para reacción diaria.
Independiente	Medio	Complementa, pero no sustituye, métricas de eficacia o tiempos de remediación.
Rentable	Alto	Una vez montada la integración con fuentes CVE/SSVC, el cálculo es barato. [web:19][web:28]

M1.2 – % de CVE relevantes con evaluación SSVC revisada localmente

Criterio	Evaluación	Comentario
Predictivo	Medio	Similar a M1.1; aporta contexto local, pero sigue siendo capacidad, no resultado.
Relevante	Alto	Clave para reflejar particularidades nacionales/sectoriales. [web:6] [web:7][web:10]
Accionable	Alto	Permite priorizar recursos analíticos del CERT nacional.
Genuino	Medio	Riesgo de “marcar revisado” sin cambios sustantivos; exige muestreo y auditoría.
Significativo	Medio	Entendible, pero requiere explicar el valor añadido de la revisión local.
Preciso	Medio	La definición de “revisión” puede variar entre equipos.
Oportuno	Bajo–Medio	Dependiente de capacidad de personal; riesgo de retrasos.
Independiente	Medio	Complementa M1.1; puede correlacionarse fuertemente.
Rentable	Medio	Requiere esfuerzo cualificado; puede ser costoso si se pretende alta cobertura.

M2.1 - % de activos críticos con identificadores normalizados

Criterio	Evaluación	Comentario
Predictivo	Medio	Habilita correlaciones futuras, pero no predice incidentes directamente.
Relevante	Alto	Base de cualquier priorización seria; alineado con NIS2 y buenas prácticas de inventario. [web:33]
Accionable	Alto	Guía programas de inventario y etiquetado; objetivo claro ("100 % de activos críticos etiquetados").
Genuino	Alto	Difícil de "maquillar" sin trabajo real; o hay CPE/SBOM o no.
Significativo	Alto	Comprensible para reguladores y dirección: "sabemos qué tenemos".
Preciso	Medio	Depende de la definición de "activo crítico" y de la calidad del inventario.
Oportuno	Medio	Se actualiza típicamente trimestral o anualmente; suficiente para planificación.
Independiente	Medio	Relacionado con otras métricas de inventario, pero con foco específico en normalización.
Rentable	Medio	Requiere inversiones en inventario y herramientas, pero es un coste estructural necesario.

M2.2 – % de activos críticos cubiertos por CVE con SSVc

Criterio	Evaluación	Comentario
Predictivo	Medio-Alto	Cuanta más cobertura, más probable que se detecten y prioricen vulnerabilidades críticas.
Relevante	Alto	Directamente ligado al objetivo de priorización nacional efectiva.
Accionable	Alto	Permite focalizar esfuerzos de integración de datos y normalización donde falta cobertura.
Genuino	Medio	Puede sobreestimarse si se consideran asociaciones débiles activo-CVE.
Significativo	Alto	Narra cuánto del “parque crítico” está realmente bajo radar SSVc.
Preciso	Medio	Depende de la calidad de correlación CPE-CVE-SSVC.
Oportuno	Medio	Recalculable mensualmente con datos automatizados.
Independiente	Medio	Amplía M2.1, pero añade dimensión “SSVC disponible”.
Rentable	Alto	Una vez integrados sistemas, el coste de cálculo es bajo. [web:19][web:28]

M3.1 – Tiempo medio global de enriquecimiento SSVc

Criterio	Evaluación	Comentario
Predictivo	Medio	Permite anticipar brechas temporales de datos que podrían traducirse en ventanas de riesgo.
Relevante	Alto	Directamente ligado a la capacidad de respuesta rápida ante nuevos CVE. [web:19] [web:22]
Accionable	Alto	Puede usarse para exigir SLA a proveedores de datos o mejorar integraciones.
Genuino	Alto	Basado en marcas de tiempo; difícil de manipular sin dejar rastro.
Significativo	Medio	Debe explicarse la relación entre “días de retardo” y riesgo operativo.
Preciso	Alto	Datos temporales claros (fecha CVE, fecha SSVc).
Oportuno	Alto	Fácil de monitorizar casi en tiempo real si las fuentes son automatizadas.
Independiente	Medio	Complementa, sin solapar, con métricas de respuesta de operadores.
Rentable	Alto	Bajo coste de cálculo una vez disponibles los metadatos.

M3.2 – Tiempo medio de ajuste SSVC local

Criterio	Evaluación	Comentario
Predictivo	Medio	Señala si el país llega “a tiempo” a contextualizar decisiones globales.
Relevante	Alto	Crítico cuando el contexto nacional difiere del global (uso tecnológico, amenazas).
Accionable	Alto	Permite definir y controlar SLA internos del CERT nacional. [web:6][web:7]
Genuino	Alto	Basado en fechas de publicación; relativamente robusto.
Significativo	Medio	Requiere explicar el valor del ajuste local.
Preciso	Alto	Fechas claras si los procesos están bien sistematizados.
Oportuno	Medio	Depende de capacidad de recursos humanos; el indicador puede llegar con retardo.
Independiente	Medio	Profundiza en M3.1, centrado en capa local.
Rentable	Medio	Exige procesos formales y registro; coste moderado.

2.2. Capa de decisión

(Para abreviar, algunas filas se presentan más compactas; el patrón es el mismo.)

M4.1 – Distribución Act/Attend/Track sobre CVE en activos críticos

Criterio	Eval.	Comentario
Predictivo	Medio	No predice incidentes, pero refleja nivel de presión futura sobre remediación.
Relevante	Alto	Núcleo del uso de SSVC a nivel nacional. [web:24][web:6]
Accionable	Alto	Permite revisar el modelo (demasiadas Act pueden ser inasumibles, demasiadas Track, complacientes).
Genuino	Medio	Riesgo de “ajustar” categorías para cumplir objetivos políticos.
Significativo	Alto	Fácil de explicar: “cuántas vulnerabilidades exigimos tratar como urgentes”.
Preciso	Alto	Si la categorización está bien definida, el conteo es claro.
Oportuno	Alto	Se actualiza conforme se toman decisiones SSVC.
Independiente	Medio	Vinculado a otras métricas de volumen, pero añade la dimensión de “acción”.
Rentable	Alto	Conteo trivial sobre datos existentes.

M5.1 – MTTR nacional para vulnerabilidades Act

Criterio	Eval.	Comentario
Predictivo	Medio–Alto	Cuanto mayor sea, más probable una exposición prolongada y futuros incidentes. [web:32][web:27]
Relevante	Alto	Directamente alineado con NIS2 y objetivos de resiliencia. [web:33]
Accionable	Alto	Permite fijar plazos y exigir planes de mejora a sectores rezagados.
Genuino	Medio	Puede “maquillarse” cerrando registros antes de la mitigación real.
Significativo	Alto	Uno de los pocos números que entendemos todos: cuánto tardamos.
Preciso	Medio	Requiere definiciones claras de “remediado” y fuentes de datos fiables.
Oportuno	Medio	Dependiente del ciclo de reporting de operadores (mensual/trimestral).
Independiente	Medio–Alto	Relacionado con % en plazo, pero aporta valor propio.
Rentable	Medio	Cálculo sencillo; el coste real está en obtener fechas fiables.

M5.2 – % de vulnerabilidades Act remediadas en plazo

Criterio	Eval.	Comentario
Predictivo	Medio–Alto	Mejor cumplimiento – menor exposición futura.
Relevante	Alto	Muy alineado con expectativas de supervisión NIS2. [web:33] [web:39]
Accionable	Alto	Claramente accionable vía planes correctivos, multas, incentivos.
Genuino	Medio	Sufre si se redefine el SLA para maquillar resultados.
Significativo	Alto	Usable en reporting público (“X % en plazo”).
Preciso	Medio	Mismas cautelas que MTTR.
Oportuno	Medio	Ciclo ligado al reporting.
Independiente	Medio	Complemento natural de MTTR.
Rentable	Medio–Alto	Cálculo trivial sobre datos de MTTR; coste marginal.

M6.1 – Tasa de discrepancias entre SSVc nacional y local

Criterio	Eval.	Comentario
Predictivo	Bajo–Medio	Indica fricción, no necesariamente riesgo inmediato.
Relevante	Medio–Alto	Importante para gobernanza y alineación, menos para operaciones puras.
Accionable	Medio	Buen disparador de revisiones y diálogos regulador–operadores.
Genuino	Medio	Puede sub-reportarse si no se exige declarar discrepancias.
Significativo	Medio	Debe interpretarse con contexto: cierta discrepancia puede ser sana.
Preciso	Bajo–Medio	Depende de disciplina de registro.
Oportuno	Bajo	Suele analizarse a posteriori.
Independiente	Alto	Métrica de gobernanza distinta de tiempos y volúmenes.
Rentable	Medio	Requiere modificaciones en procesos de reporting.

2.3. Capa de eficacia y resiliencia

M7.1 - % de incidentes graves debidos a Track/Attend

Criterio	Eval.	Comentario
Predictivo	Alto	Cuando esta métrica empeora, hay un problema de modelo que anticipa futuros fallos de priorización. [web:16][web:20]
Relevante	Alto	Directamente vinculado a la eficacia del modelo SSVC.
Accionable	Alto	Motiva recalibración de puntos de decisión y plazos.
Genuino	Medio	Depende de la capacidad de atribuir incidentes a vulnerabilidades específicas.
Significativo	Alto	Mide “falsos negativos”; conceptualmente potente.
Preciso	Medio-Bajo	Atribución y clasificación pueden ser discutibles.
Oportuno	Bajo-Medio	Requiere análisis posterior a incidentes; no es en tiempo real.
Independiente	Alto	Complementa métricas de cumplimiento de SLA con impacto real.
Rentable	Medio	Exige análisis de incidentes, pero suele hacerse por otros motivos.

M8.1 – Tiempo acumulado de exposición a KEV-Act (días-activo)

Criterio	Eval.	Comentario
Predictivo	Alto	Más “área bajo la curva” de exposición → mayor probabilidad de explotación. [web:25][web:12]
Relevante	Alto	KEV recoge vulnerabilidades explotadas; la exposición directa es crítica. [web:6]
Accionable	Alto	Permite fijar objetivos de reducción de exposición y priorizar sectores.
Genuino	Medio	Requiere datos de inventario y fechas correctas; posible subregistro.
Significativo	Medio-Alto	Concepto algo técnico, pero explicable: “cuánto tiempo hemos estado abiertos de par en par”.
Preciso	Medio	Calidad depende de la granularidad de inventario y reporting.
Oportuno	Medio	Calculable mensualmente; útil para supervisión.
Independiente	Medio	Relacionado con MTTR y % en plazo, pero introduce la dimensión “volumen de activos”.
Rentable	Medio	Cálculo algo más complejo; pero automático una vez montado.

M9.1 – Reducción interanual del backlog crítico

Criterio	Eval.	Comentario
Predictivo	Medio	Tendencia decreciente sugiere riesgo más controlado, pero puede deberse a cambios de criterios. [web:27][web:32]
Relevante	Alto	Directamente conectado con la sostenibilidad de la remediación.
Accionable	Alto	Apoya decisiones de recursos (más personal, automatización, cambios de prioridades).
Genuino	Medio	Puede manipularse reclasificando vulnerabilidades a menor criticidad.
Significativo	Medio	Requiere contexto de cambios de modelo y volumen de nuevas vulnerabilidades.
Preciso	Medio	Depende de definición estable de “crítico”.
Oportuno	Medio–Alto	Calculable trimestral/anual con datos de ticketing.
Independiente	Medio	Relacionado con MTTR y % en plazo, pero mide “stock”, no “flujo”.
Rentable	Alto	Cálculo sencillo una vez se tiene inventario de tickets.

M9.2 – Reducción del MTTR para Act tras SSVc

Criterio	Eval.	Comentario
Predictivo	Medio-Alto	Si el MTTR baja tras SSVc, cabe esperar menos exposición futura.
Relevante	Alto	Directamente alineado con el objetivo de implantar SSVc como acelerador de priorización. [web:19]
Accionable	Alto	Ayuda a evaluar si SSVc está teniendo el efecto deseado y justificar su extensión.
Genuino	Medio	Podría mejorarse “a la fuerza” cambiando criterios de cierre.
Significativo	Alto	Fácil de explicar: “desde que usamos SSVc, tardamos X días menos”.
Preciso	Medio	Sujetos a la misma precisión que MTTR bruto.
Oportuno	Medio	Requiere ventanas comparables (antes/después).
Independiente	Medio	Derivado de MTTR, pero con foco en impacto de la iniciativa SSVc.
Rentable	Alto	Bajo coste, usa datos ya recopilados.

3. Uso de la matriz PRAGMATIC

- Selección de métricas “estrella”: las que puntúan Alto en Relevante, Accionable y Significativo son candidatas a convertirse en KPIs nacionales.
- Identificación de métricas “caras”: aquellas con Rentable = Bajo/Medio y aportación limitada pueden reservarse para análisis específicos o pilotos.
- Equilibrio de cartera: evitar tener solo métricas de “capacidad” (datos, inventario) o solo de “resultado” (incidentes); la combinación ofrece una visión completa. [web:27][web:32][web:33]

La matriz puede traducirse a una escala numérica (por ejemplo, Alto=3, Medio=2, Bajo=1) para calcular un “score PRAGMATIC” por métrica y facilitar comparaciones.